

Sociální inženýrství a sociální aspekty kybernetické bezpečnosti

Příprava k maturitě - SPŠT IT

Obsah

1 Sociální inženýrství	2
1.1 Phishing	2
1.2 Spear phishing	3
1.3 Honey trap	3
2 Sociální aspekty kybernetické bezpečnosti	4
2.1 Digitální stopa	4
2.2 Kyberšikana	4
2.3 Kyberstalking	5
2.4 Kybergrooming	5
Odpovědi na zadané podotázky	5
„V čem spočívá sociální inženýrství a na čem je založeno.“ .	5
„Vyjmenovat techniky sociálního inženýrství a uvést jejich vektor útoku.“	6
„Popsat Phishing, Spear phishing, Vishing, Smishing, Whaling, Quid Pro Quo a další, příklady.“	6
„Způsoby ochrany proti útokům sociálního inženýrství.“	6
„Definice a dělení digitální stopy a způsoby její minimalizace.“	6
„Popsat kyberstalking, kyberšikanu a kybergrooming.“	6
Další materiály a zdroje	6

Sociální inženýrství je technika manipulace lidí s cílem získat důvěrné informace, přístup k systémům nebo provést neautorizované akce. V kontextu kybernetické bezpečnosti se sociální inženýrství zaměřuje na zneužití lidské psychologie a důvěry, aby útočník dosáhl svých cílů. Tento typ útoku může být velmi účinný, protože často obchází technické bezpečnostní opatření a spoléhá na lidskou chybu nebo nedostatek informací.

1 Sociální inženýrství

Sociální inženýrství je technika manipulace s lidskou myslí pomocí různých sociotechnických metod (psychologie) a metod přesvědčování.

Útočníci ví, že sociální inženýrství v textové podobě moc nefunguje, protože

- lidé mají větší čas na rozhodnutí
- mluvené slovo a osobní aktivita je více účinná

Sociální inženýrství je založeno na

- důvěryhodnosti
- přesvědčivosti
- emočním nátlaku

Nejčastějším způsobem je email, ale v poslední době se rozšiřuje formou telefonních hovorů. V poslední době bylo nejvíce slyšet o investičních poradcích, kteří okrádají starší, nic netušící lidi.

Technik sociálního inženýrství je spoustu mezi nejznámější a nejvíce používané například patří

- phishing
- spear phishing
- vishing
- whaling
- honey trap

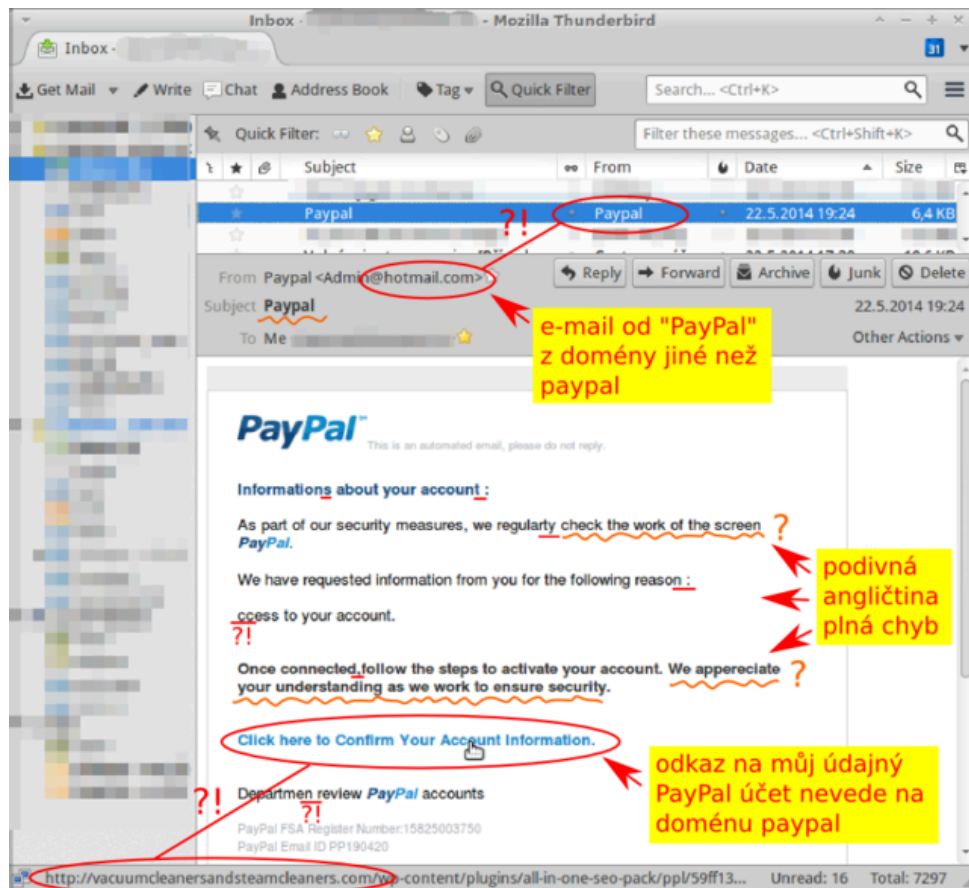
1.1 Phishing

Phishing je forma podvodné, většinou e-mailové, zprávy, která má za cíl získat citlivé informace, přístupy k identitě oběti nebo údaje platební karty. Nejčastěji je phishing generalizovaný bez cílení na svou oběť. Šířen bývá masově (stejně jako spam) pomocí botů. Oběť je často lákána na emotivně motivovanou zprávu.

Vektory útoku

- email,
- sociální sítě,
- webové stránky.

Hlavní ochranou je školení a informovanost uživatelů.



Obrázek 1: „Ukázka phishingového emailu“

1.2 Spear phishing

Spear phishing je cílený phishing na konkrétní osobu nebo společnost. Směřovaný je na základě získaných informací o cílené oběti. Hlavním cílem útočníka je získat citlivé informace o oběti, finanční prostředky, nebo provedení určité akce vedoucí k další eskalaci útoku.

Spear phishing využívá emoce v obsahu zprávy

- naléhavost sdělení nebo postavení odesílatele,
- např. případ, kdy ředitel píše řadovému zaměstnanci.

Útočník používá

- velmi podobné názvy domény (typosquatting) např.: g0ogle.com, gooogles.com,
- skutečná jména zaměstnanců společnosti,
- podvodné kopie webových stránek.

1.3 Honey trap

Při tomto útoku se útočník vydává za zajímavou, populární, či jinak atraktivní osobu, aby snáze navázal vztah se svou obětí, od které následně získá citlivé informace nebo finanční prostředky. Útočník má často vytvořené profily na sociálních sítích, webové stránky, falešné bankovní účty, upravené fotografie a mnoho dalšího.

Často se útočníci vydávají za

- příslušníky armády,
- lékaře v zahraničí,
- atraktivní ženy
- celebrity.

2 Sociální aspekty kybernetické bezpečnosti

2.1 Digitální stopa

Většina uživatelů zanechává v prostředí internetu určité informace, přičemž některé z nich jsou získávány dalšími stranami „bez souhlasu“ uživatele.

Digitální stopu lze rozdělit na

- aktivní – stopa, která je zanechána vědomou činností,
- pasivní – automaticky vzniká jako vedlejší produkt aktivní stopy.

Četnost a citlivost informací obsažených v digitální stopě je závislá na chování uživatele, zejména v tom, jaké online služby a nástroje používá.

Digitální stopa se skládá z uživatelských dat a metadat

- uživatelská data – e-mail, jméno, datum narození, bydliště,
- metadata – IP adresa, GPS souřadnice, časové známky.

Každý kdo nějakým způsobem používá internet má digitální stopu, což znamená, že vzniká pohybem na internetu. Každý uživatel může ovlivnit velikost svojí digitální stopy, například svým chováním na internetu.

Podle velikosti digitální stopy na internetu je se odvíjí míra anonymity. Čím větší digitální stopa, tím klesá míra anonymity.

Pro minimalizaci digitální stopy je vhodné

- používání více uživatelských účtů,
- podpůrná rozšíření do prohlížeče,
- vyhledávač DuckDuckGo,
- prohlížeč Brave/Tor,
- VPN.

2.2 Kyberšikana

Kyberšikana je druh šikany využívající informační a komunikační technologie k ublížení druhému (vydírání, ubližování, ztrapňování, obtěžování apod.). Aktéry kyberšikany jsou jako u klasické šikany: agresor, oběť a přihlížející.

Problémovým aspektem může být anonymita útočníka

- falešný uživatelský profil vytvořený agresorem,

- neveřejný prostor (např. soukromá diskuse),
- místo a čas útoku nelze vždy předpokládat.

Není snadné rozeznat dopad a dlouhodobé působení kyberšikany na oběť. Kyberšikana může být způsobena také neúmyslně (např. nevhodný vtip), kdy se může se rozvinout do podoby kolektivní kyberšikany.

Nejčastější projevy kyberšikany

- Pořizování zvukových záznamů, videí nebo fotografií, jejich upravení a následné zveřejňování s cílem úmyslně poškodit vybranou osobu (předem připravený fyzický útok, natáčení učitele apod.).
- Zasílání urážlivých a zastrašujících zpráv nebo pomluv (e-mail, SMS, ...).
- Vytváření internetových stránek, které urážejí, pomlouvají nebo ponižují konkrétní osobu (blogy, diskuzní fóra a jiné webové stránky).
- Zneužívání cizího účtu – krádež identity (e-mail, sociální sítě apod.).

2.3 Kyberstalking

Je druh stalking, kdy pachatel využívá informační a komunikační technologie k zastrašování, vydírání a obtěžování oběti. Tato forma je oproti běžnému stalkingu snazší, levná a anonymní.

2.4 Kybergrooming

Termín kybergrooming (child grooming) označuje chování uživatelů internetu (predátorů), které má v jejich oběti vyvolat falešnou důvěru a přimět ji k osobní schůzce v reálném světě. Výsledkem schůzky může být např. sexuální zneužití, fyzické násilí, zneužití oběti pro dětskou prostituci, k výrobě dětské pornografie apod. Kybergrooming je druhem psychické manipulace, ve které komunikuje dospělý uživatel s dítětem (komunikace s obětí často pod falešnou identitou). Využívá celou řadu strategií: zrcadlení (mirroring), spear phishing, profilování oběti, vábení a uplácení, strategie snižování zábran dětí a mládeže zaváděním sexuálního obsahu do konverzace, izolační metody, strategie manipulace dětí prostřednictvím fotografií opačného pohlaví a další techniky.

Odpovědi na zadané podotázky

Každá otázka na začátku odpovědi obsahuje odkaz na konkrétní kapitolu v zápise s proklikem

„V čem spočívá sociální inženýrství a na čem je založeno.“

„Vyjmenovat techniky sociálního inženýrství a uvést jejich vektor útoku.“

„Popsat Phishing, Spear phishing, Vishing, Smishing, Whaling, Quid Pro Quo a další, příklady.“

„Způsoby ochrany proti útokům sociálního inženýrství.“

„Definice a dělení digitální stopy a způsoby její minimalizace.“

„Popsat kyberstalking, kyberšikanu a kybergrooming.“

Další materiály a zdroje

- Youtube - Téma
 - Wiki - Téma
-